Section 1 — Incident Header

Incident ID: INC-20260430-009
Date: 30-Apr-2026
Time Opened (IST): 10:42 IST
Severity: Critical
Client: GlobalTrade Export Co.
Industry: Finance (International Trade & Export)
L1 Analyst: Arjun Mehta
L2 Analyst: Rohan Desai
L3 Analyst: Nisha Kapoor
Current Status: Under Investigation — Escalated to L2
Sentinel Incident Number: 457892

Section 2 — Client & Environment Context

GlobalTrade Export Co. is a mid-sized financial trading firm headquartered in Mumbai, specializing in cross-border commodity exports across Southeast Asia, the Middle East, and Europe. With approximately 850 employees spread across its Mumbai headquarters and two regional offices in Dubai and Singapore, the company handles high-value international transactions daily — often involving time-sensitive wire transfers running into millions of dollars.

The organization operates in a high-risk threat landscape where financial fraud, particularly Business Email Compromise (BEC), is a persistent concern. Their finance department, consisting of 42 employees, has privileged access to banking portals, SWIFT interfaces, and internal ERP systems used for payment approvals and vendor settlements. The CEO and CFO regularly authorize urgent international transfers, making their identities prime targets for impersonation attacks.

From a technical standpoint, GlobalTrade runs a hybrid identity environment — on-prem Active Directory synchronized with Azure AD via Azure AD Connect. All users authenticate through Microsoft 365 with E5 licensing, enabling Microsoft Defender for Endpoint, Defender for Office 365 Plan 2, and Microsoft Sentinel as the central SIEM. Conditional Access policies enforce MFA across all users, though legacy email protocols remain partially enabled for specific third-party integrations.

The company's email infrastructure is fully cloud-hosted in Microsoft 365. Defender for Office 365 provides anti-phishing and Safe Attachments protection, but the organization has recently noted an increase in sophisticated impersonation attempts targeting senior leadership. Display

name spoofing — where attackers mimic executive identities without compromising actual accounts — has emerged as a growing concern.

On the network side, employees connect via secure VPN when remote, with split tunneling enabled for SaaS applications. Finance team members frequently access banking systems during early morning and late evening hours due to global time zone overlaps, which can sometimes blur the distinction between legitimate and anomalous activity.

Compliance requirements include adherence to ISO 27001 standards and periodic financial audits, making any attempted fraud not just a financial risk but also a regulatory concern.

For this particular week, the finance team is processing end-of-quarter settlements — a period historically associated with increased transaction volume, urgency, and reduced tolerance for delays. This operational pressure creates an ideal environment for social engineering attacks to succeed if not detected quickly.

Section 3 — Attack Narrative (Attacker's Perspective)

The attacker had been watching GlobalTrade for weeks.

They didn't need to breach the network. They didn't need malware. All they needed was timing — and credibility.

The reconnaissance phase began with publicly available information. LinkedIn profiles revealed the company's leadership structure. The CEO's name appeared frequently in press releases announcing new trade agreements. More importantly, finance managers and their roles were easily identifiable — individuals responsible for processing international wire transfers.

The attacker noted a pattern: end-of-quarter periods brought urgency. Payments had to move fast. Approvals were often rushed.

That was the window.

They registered a domain that looked deceptively similar to the company's legitimate one — swapping a single character that would go unnoticed in a quick glance. Using this domain, they configured SMTP services capable of sending emails that would pass basic delivery checks, even if authentication mechanisms like SPF and DKIM failed alignment.

Next came crafting the message.

The attacker studied prior communications from executives — tone, formatting, signature blocks. The email they composed was short, direct, and urgent:

A confidential payment.
A trusted vendor.
A strict deadline.

No room for hesitation.

The display name was set to the CEO's full name — the same one used internally. The actual email address was slightly altered, but buried behind the familiar name, it was unlikely to draw scrutiny.

The message was sent at 10:38 IST — a deliberate choice. Late morning, when finance teams are active, but often juggling multiple tasks. The subject line conveyed urgency without raising suspicion.

Minutes after sending, the attacker waited.

No follow-up. No second message. Silence was part of the strategy. Too much pressure could trigger doubt. The goal was simple — let the authority of the CEO's name do the work.

If the finance manager acted quickly, the attacker would receive the funds in an offshore account routed through multiple intermediary banks, making recovery nearly impossible.

This wasn't a technical attack.

It was psychological precision — exploiting trust, authority, and timing.

And it only needed to work once.

Section 4 — Detection & Alert

The incident did not begin with a traditional automated alert. It started with a human escalation — but within seconds, that human signal aligned with an existing Microsoft Sentinel analytics rule.

At **10:42 IST**, a new **Critical severity incident** appeared in the Sentinel Incidents queue, triggered by a Defender for Office 365 signal correlated with a custom analytics rule: **"Display Name Impersonation — Executive Targeting"**.

Rule Logic (KQL):

```
EmailEvents
| where TimeGenerated > ago(30m)  // Focus on recent emails
| where SenderFromDomain !contains "globaltrade.com"  // External sender
```

```
| where SenderDisplayName in~ ("Rajiv Mehra", "CEO Rajiv Mehra")  // CEO display name impersonation
| where Subject has_any ("urgent", "wire", "transfer", "payment")  // Financial urgency keywords
| project TimeGenerated, SenderFromAddress, SenderDisplayName, RecipientEmailAddress, Subject, NetworkMessageId
```

The rule triggered on a single email event with the following characteristics:

- **SenderFromAddress:** rajiv.mehra@gl0baltrade.co
- **SenderDisplayName:** Rajiv Mehra
- **RecipientEmailAddress:** finance.manager@globaltrade.com
- **Subject:** "Urgent Wire Transfer Required — Confidential"
- **Timestamp:** 10:38 IST

Although SPF and DKIM checks failed, the email was still delivered due to the organization's current mail flow configuration allowing certain external messages into the inbox for review rather than outright rejection.

Simultaneously, Defender for Office 365 flagged the email for **display name impersonation**, but it had not yet been auto-remediated when the finance manager saw it.

In the Sentinel Incidents queue, the alert appeared as:

- **Title:** Executive Impersonation — Potential BEC Attempt
- **Severity:** Critical
- **Entities:**
    - User: finance.manager@globaltrade.com
    - Sender: rajiv.mehra@gl0baltrade.co
    - Domain: gl0baltrade.co
- **TimeGenerated:** 10:42 IST

The alert stood out immediately — not just because of its severity, but because it aligned perfectly with a real-time user report that arrived seconds earlier.

The system had caught the pattern.

Now it was up to the analyst to determine whether the threat was contained — or already in motion.

Section 5 — L1 Triage (Arjun Mehta)

At **10:41 IST**, Arjun was midway through reviewing a Medium-severity endpoint alert — a routine Defender for Endpoint signal involving a suspicious but ultimately benign PowerShell execution. His left monitor showed the Sentinel queue, sorted by severity. His right monitor had the investigation pane open, along with a CyberChef tab he hadn't yet closed.

His desk phone rang.

He glanced at the caller ID — **Finance Department**.

He picked up.

"Arjun, this is Neha from finance," the voice said quickly. "I just received an email from Rajiv sir — urgent wire transfer. It feels… off. Can you check?"

Arjun straightened in his chair. His eyes shifted to the Sentinel queue instinctively — and at that exact moment, the new **Critical incident** appeared at the top.

He muttered under his breath, reading it out loud as he always did:

"Executive impersonation… potential BEC…"

"Neha, don't take any action on that email," he said immediately. "Do not initiate any transfer. I'm checking it right now."

He clicked into the incident.

The right panel expanded. He scanned the entities first — finance.manager@globaltrade.com… sender domain gl0baltrade.co.

"Zero instead of 'o'…" he murmured.

That was enough to raise suspicion, but not enough to conclude.

He opened **Tab 3 — Defender for Office 365** on his second monitor. He pasted the **NetworkMessageId** from the alert into the message trace search.

The email loaded.

He clicked into **"View Message Details"** and scrolled directly to the authentication section.

- **SPF:** Fail

- **DKIM:** Fail
- **DMARC:** Fail (Policy: Reject)

Arjun paused.

“If DMARC is reject… why was it delivered?” he thought.

He leaned back slightly, thinking. Could this be a legitimate forward? Could the CEO have sent it from a personal device or external account?

He looked back at the sender address.

No. The domain wasn’t theirs. It was a lookalike.

He opened the email body preview.

Short. Direct. No signature discrepancies. No obvious grammatical errors.

That was what made it dangerous.

He switched to **Tab 2 — Entity Behavior** for the recipient.

He checked recent activity — no unusual login, no suspicious mailbox rules, no anomalies.

That told him something important:

This wasn’t a compromised account.

This was impersonation.

He opened his physical notepad and wrote:

“CEO spoof — external domain — SPF/DKIM fail — finance target — urgent wire”

Then he made the decision.

He clicked **“Add Comment”** in Sentinel and typed:

“Email identified as display name spoofing of CEO. Sender domain gl0baltrade.co (lookalike). SPF, DKIM, DMARC all failed. No evidence of CEO account compromise. Targeted finance user with urgent wire request. Likely BEC attempt. No transaction executed yet (confirmed via user call).”

He changed nothing about the severity — it was already Critical.

At **10:45 IST**, he opened Microsoft Teams and navigated to **SOC-Incidents channel**.

He typed:

Escalation Message:

[CRITICAL ESCALATION — BEC ATTEMPT]
Alert: Executive Display Name Impersonation (CEO Rajiv Mehra)
Target: finance.manager@globaltrade.com
Key Observations: External domain (gl0baltrade.co), SPF/DKIM/DMARC all failed, email requesting urgent wire transfer. User confirmed no action taken yet.
Initial Assessment: High-confidence BEC attempt — likely spoofed, not account compromise.
Request: Need validation of whether any similar emails delivered to other users + confirmation no follow-on mailbox rules or login activity.

He hit send.

Then he pinged Rohan directly.

And waited.

Section 6 — L2 Investigation (Rohan Desai)

Rohan read the Teams notification before opening Sentinel.

He always did.

At **10:46 IST**, seated at his L2 desk behind the L1 row, he leaned slightly forward, eyes scanning Arjun's escalation message on his right monitor.

"High-confidence spoof… no compromise yet…" he murmured.

Good. That meant time was still on their side.

He opened the Sentinel incident on his left monitor, expanding the investigation graph. One sender. One recipient. One domain.

Clean.

Too clean.

He didn't trust it.

He turned to his center monitor — Notepad++ already open — and began typing his first question:

"Did this attacker target only one user, or multiple?"

He wrote the query.

```
EmailEvents
| where TimeGenerated > ago(1h)  // Scope to last hour
| where SenderFromDomain == "gl0baltrade.co"  // Attacker domain
| summarize RecipientCount = dcount(RecipientEmailAddress), Recipients =
make_set(RecipientEmailAddress)
```

He executed it.

Result:

- RecipientCount: 3
- Recipients:
  - finance.manager@globaltrade.com
  - accounts.payable@globaltrade.com
  - treasury.ops@globaltrade.com

Rohan exhaled slowly.

“This wasn’t targeted. This was a batch.”

He pivoted immediately.

Second question: Did anyone else engage with the email?

```
EmailEvents
| where TimeGenerated > ago(1h)
| where SenderFromDomain == "gl0baltrade.co"
| project RecipientEmailAddress, DeliveryAction, Timestamp = TimeGenerated
| join kind=leftouter (
   OfficeActivity
   | where TimeGenerated > ago(1h)
   | where Operation in ("MailItemsAccessed", "New-InboxRule")
   | project UserId, Operation, TimeGenerated
) on $left.RecipientEmailAddress == $right.UserId
```

The results came back.

- finance.manager — accessed email (expected)
- accounts.payable — no activity
- treasury.ops — no activity

No inbox rules. No suspicious actions.

Rohan nodded.

Containment window still open.

Now the bigger question:

Was the CEO account actually compromised?

He pivoted to **SigninLogs**.

```
SigninLogs
| where TimeGenerated > ago(2h)
| where UserPrincipalName == "rajiv.mehra@globaltrade.com"  // CEO account
| project TimeGenerated, IPAddress, Location, ResultType, AuthenticationRequirement
```

Results:

- All logins from Mumbai
- All successful with MFA
- No unfamiliar IPs
- No failed attempts spike

Rohan leaned back.

“Good. Clean account.”

That confirmed Arjun’s hypothesis.

Pure spoof.

Now he moved to enrichment.

He opened **VirusTotal** on his third monitor and entered **gl0baltrade.co**.

- Domain age: **3 days**
- Reputation: **Malicious — flagged by 6 vendors**

He checked **WHOIS**:

- Registered anonymously
- Registrar: offshore provider
- No historical records

He added it to his IOC list.

Then he reconstructed the timeline.

Attack Timeline

Time (IST)	Event	Data Source	MITRE Technique
10:38	Phishing email sent to 3 finance users	EmailEvents	T1534 — Internal Spearphishing
10:41	Finance manager opens email	OfficeActivity	T1204 — User Execution
10:42	Sentinel alert triggered	Sentinel Analytics	Detection
10:43	User calls SOC	External trigger	—
10:45	L1 escalation to L2	Teams	—
10:47	L2 confirms multi-recipient targeting	EmailEvents	—
10:49	L2 verifies no mailbox compromise	SigninLogs	—

IOC Table

IOC Value	Type	Source	Enrichment Result
gl0baltrade.co	Domain	EmailEvents	Malicious — 3 days old, flagged in VirusTotal
rajiv.mehra@gl0baltrade.co	Email	EmailEvents	Spoofed identity — lookalike domain
185.243.115.72	IP (mail relay)	EmailEvents headers	AbuseIPDB: 87% malicious confidence

---

MITRE ATT&CK Mapping

- **T1534 — Internal Spearphishing (BEC impersonation)**
- **T1204 — User Execution (email interaction)**

Rohan turned back to Notepad++ and began writing containment actions.

Not generic.

Precise.

Containment Recommendations

1. Block domain **gl0baltrade.co** in **Microsoft Defender for Office 365 Tenant Allow/Block List**
2. Create transport rule:
    - Condition: SenderDisplayName = “Rajiv Mehra” AND SenderDomain ≠ globaltrade.com
    - Action: Quarantine message
3. Initiate message trace purge for all emails from **gl0baltrade.co** across tenant
4. Notify all three targeted users — confirm no financial action taken
5. Add sending IP **185.243.115.72** to **Exchange Online Protection block list**
6. Review DMARC policy enforcement — ensure reject policy is strictly enforced without delivery fallback

---

At **10:55 IST**, Rohan pushed his findings into the Sentinel incident comments.

He paused for a moment before hitting save.

No compromise.

No loss.

But only because the human detected it in time.

He typed one final line:

“Incident contained pre-impact. Pure impersonation attempt. No evidence of account compromise.”

Then he leaned back.

And only then allowed himself to move to the next case.

Section 7 — L3 Detection Tuning (Nisha Kapoor)

At **12:10 IST**, nearly an hour after Rohan had closed the active investigation, Nisha pulled the incident report up on her ultra-wide monitor. The SOC floor had settled back into its usual rhythm — low conversation, keyboard clicks, the occasional alert tone — but her focus was elsewhere.

She didn’t look at the conclusion first.

She started from the detection.

Scrolling back through Rohan’s notes, she paused at one line:

“Incident contained pre-impact. Pure impersonation attempt.”

She leaned back slightly.

“Contained… but only because the user called,” she said quietly.

That was the real signal.

She opened the **Microsoft Sentinel Analytics Rules editor** and searched for the rule that fired: **“Display Name Impersonation — Executive Targeting”**

The rule loaded. She read the KQL slowly — not skimming, not assuming.

Before-State Rule (Current Detection Logic)

```
EmailEvents
| where TimeGenerated > ago(30m)
| where SenderFromDomain !contains "globaltrade.com"
| where SenderDisplayName in~ ("Rajiv Mehra", "CEO Rajiv Mehra")
| where Subject has_any ("urgent", "wire", "transfer", "payment")
| project TimeGenerated, SenderFromAddress, SenderDisplayName, RecipientEmailAddress, Subject, NetworkMessageId
```

She tapped her pen lightly against the desk.

The rule wasn't wrong.

It worked.

But it worked **too late**.

She scrolled back to the timeline. The email was delivered at **10:38 IST**. The alert fired at **10:42 IST**.

Four minutes.

Enough time for a wire transfer to be initiated.

She opened Notepad++ and wrote her observation:

"Rule detects impersonation only after delivery — no pre-delivery or multi-recipient correlation context."

She looked back at Rohan's findings — three recipients.

The rule treated them as three separate events.

That was the gap.

She began rewriting.

Identified Weakness (Single Sentence)

The rule detects impersonation emails individually after delivery but fails to correlate multiple simultaneous targets, delaying detection of coordinated BEC campaigns.

After-State Rule (Improved Detection Logic)

```
EmailEvents
| where TimeGenerated > ago(15m)  // Reduce detection window for faster alerting
| where SenderFromDomain !contains "globaltrade.com"  // External sender
| where SenderDisplayName in~ ("Rajiv Mehra", "CEO Rajiv Mehra")  // Executive impersonation
| where Subject has_any ("urgent", "wire", "transfer", "payment")  // Financial urgency keywords
```

```
| summarize RecipientCount = dcount(RecipientEmailAddress),
        Recipients = make_set(RecipientEmailAddress),
        FirstSeen = min(TimeGenerated)
        by SenderFromAddress, SenderDisplayName, SenderFromDomain
| where RecipientCount >= 2  // Trigger only when multiple users are targeted
| project FirstSeen, SenderFromAddress, SenderDisplayName, SenderFromDomain,
RecipientCount, Recipients
```

She read it again, line by line.

This time, she imagined the incident playing out again.

The email hits three inboxes.

Instead of three low-signal events…

One high-confidence alert.

Earlier.

Louder.

She added a final comment in her draft:

“This improves detection by identifying coordinated impersonation campaigns instead of isolated emails, reducing reliance on user reporting and enabling faster SOC response before user interaction.”

She saved the draft.

For Nisha, the incident wasn’t about what happened.

It was about what almost happened — and making sure next time, the system gets there first.

She closed the editor.

And moved on.

Section 8 — Final Incident Report

Part A — Executive Summary

On 30-Apr-2026, GlobalTrade Export Co. was targeted by a fraudulent email impersonating the CEO, requesting an urgent wire transfer. The email was sent from a deceptive external domain designed to resemble the company's legitimate address.

A finance team member identified the request as suspicious and reported it to the SOC before any financial action was taken. The SOC confirmed this was a spoofing attempt and not a compromise of internal systems.

No funds were transferred, and no accounts were breached. The malicious domain and sender were promptly blocked, and preventive measures have been strengthened to reduce future risk.

Part B — Full Technical Summary

Incident Type:
Business Email Compromise (BEC) — CEO Impersonation

MITRE ATT&CK Techniques:

- T1534 — Internal Spearphishing
- T1204 — User Execution

Timeline Summary

Time (IST)	Event
10:38	Malicious email sent to 3 finance users
10:41	Finance manager opens email and identifies suspicion
10:42	Sentinel alert triggered (display name impersonation)
10:43	User reports incident to SOC
10:45	L1 escalation to L2
10:47–10:55	L2 investigation confirms spoofing, no compromise
10:55	Containment actions initiated

Impact Assessment

- **Financial Impact:** None (no transaction executed)

- **Account Compromise:** None detected
- **Data Exposure:** None
- **Operational Impact:** Minimal — contained at initial stage

---

IOC List

IOC Value	Type	Source	Enrichment Result
gl0baltrade.co	Domain	EmailEvents	Malicious — newly registered, flagged in VirusTotal
rajiv.mehra@gl0baltrade.co	Email Address	EmailEvents	Spoofed identity
185.243.115.72	IP Address	Email header	AbuseIPDB: High-risk (87% confidence)

Containment Actions Taken

1. Blocked domain **gl0baltrade.co** in Microsoft Defender for Office 365
2. Removed all instances of the email from affected mailboxes
3. Blocked sending IP **185.243.115.72** in Exchange Online Protection
4. Notified all targeted users and confirmed no action taken
5. Reviewed and validated CEO account activity — no compromise detected

---

Lessons Learned

- Display name impersonation remains highly effective despite authentication failures
- User awareness played a critical role in early detection
- Existing detection rules require correlation logic to identify multi-target campaigns faster
- Email delivery policies need stricter enforcement of DMARC reject outcomes

---

Action Items

Action	Owner	Priority	Target Date
Implement enhanced impersonation detection rule (multi-recipient correlation)	Nisha Kapoor (L3)	High	02-May-2026
Enforce strict DMARC reject policy without delivery fallback	Email Security Team	High	05-May-2026
Conduct targeted BEC awareness training for finance department	Security Awareness Team	Medium	10-May-2026
Implement transport rule for CEO display name spoofing	Messaging Team	High	03-May-2026
Review external email tagging/banner policies	IT Security Team	Medium	08-May-2026